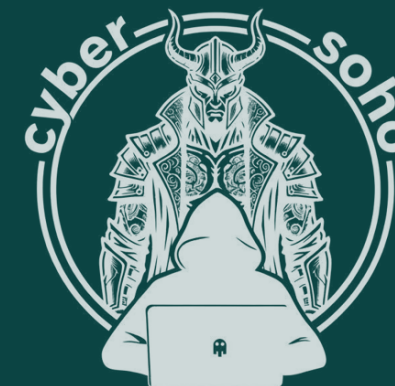




Class 12: Cyber Defense Tools and Techniques

Network firewalls, zoning rules, session and cache protection, and practical **DoS** (Denial-of-Service) defense

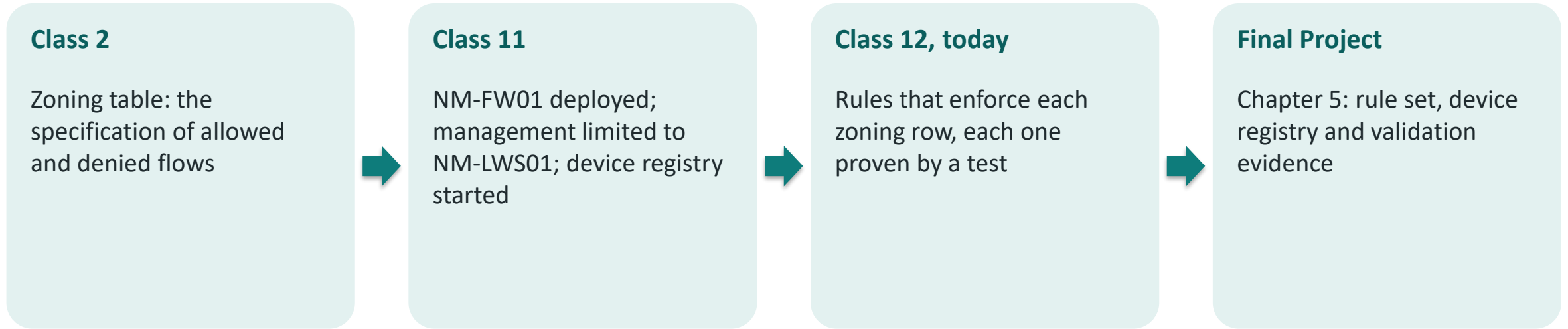
Saturday, September 26, 2026, 8:30 am **EDT** (Eastern Daylight Time) | LAB_05 part 2 of 2 | NorthMaple Accounting Inc. (fictional)

Today's 60 minutes

Opening 4 min	1 Firewalls 13 min	2 Zoning to rules 14 min	3 Sessions and caches 13 min	4 DoS defense 11 min	LAB_05 5 min



0 From Class 11 to today



The laboratory rule for everything that follows

Every connection test, every script and every capture of this class runs only inside your own isolated laboratory, against your own virtual machines.

Unauthorized use of a computer is a criminal offence in Canada (Criminal Code, sections 342.1 and 430(1.1)). If a test seems to touch a system you do not own: stop and ask.

0 What you will be able to do after this hour

1

Explain how a stateful firewall decides for one packet, and why a staff laptop on Wi-Fi meets the same rules as a wired **PC** (Personal Computer).

2

Translate each zoning row into a rule on the right interface, in the right order, with an allowed and a blocked test.

3

Name the controls that stop session hijacking and protect the **ARP** (Address Resolution Protocol), **DNS** (Domain Name System) and web caches.

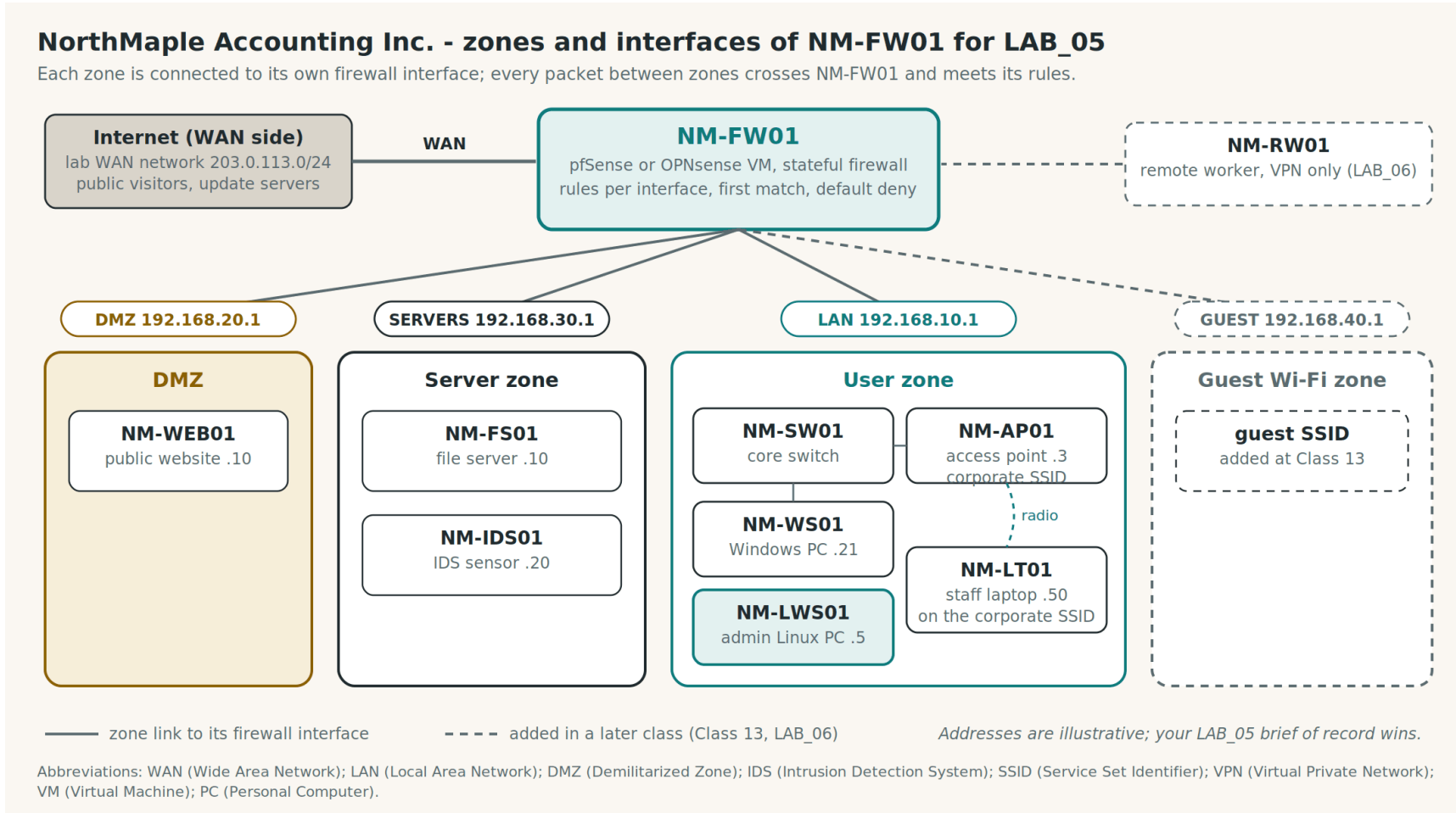
4

Classify a **DoS** (Denial-of-Service) attack by the resource it exhausts, and choose the layer that can absorb it.

5

Describe the LAB_05 deliverables: firewall rule set, device registry and validation evidence.

0 The network you are defending



Every packet between zones crosses NM-FW01 and meets the rules of the interface where it enters. Addresses are illustrative: use those of your own brief.

1

Lesson 1 of 4, about 13 minutes

Network firewalls: configuration for wired and wireless environments

In this lesson

- How a stateful firewall reads a packet and remembers connections
- First match, default deny, and the three actions
- Wired zones: dedicated interfaces and VLANs
- Wireless: what the access point decides and what the firewall decides

1

What a network firewall examines

Protocol	Source address	Source port	Destination address	Destination port	Arrival interface
TCP	192.168.10.21	51000	203.0.113.80	443	LAN

The five fields form the 5-tuple; the arrival interface decides which rule list is read.

- A **network firewall** forwards or drops each packet that moves between network segments, following an ordered rule set.
- It reads the **5-tuple**: protocol (**TCP** (Transmission Control Protocol) or **UDP** (User Datagram Protocol); **ICMP** (Internet Control Message Protocol) for control messages), source and destination addresses, source and destination ports.
- A port identifies a service on a host: 443 **HTTPS** (Hypertext Transfer Protocol Secure), 445 **SMB** (Server Message Block) file sharing, 22 **SSH** (Secure Shell), 53 **DNS** (Domain Name System), 3389 **RDP** (Remote Desktop Protocol).
- The **arrival interface** comes first: a rule written for **LAN** (Local Area Network) is never read for a packet that arrived on **WAN** (Wide Area Network).

1 Network firewall and host firewall work together

N Network firewall: NM-FW01 (today)

- Protects every host of a zone at the same time
- Sees only traffic that moves between zones
- Decides which zones may talk, and on which services
- One policy per interface

H Host firewall: Class 6, LAB_03

- Protects one machine only
- Sees all traffic of that machine, even inside its own zone
- Decides which services the machine exposes
- Windows Defender Firewall, UFW or firewallD

Two layers of defense in depth: traffic that stays inside the user zone never crosses NM-FW01, so each workstation's host firewall is the only filter it meets.

1

Stateless and stateful filtering

Stateless filter

- Judges each packet alone
- Needs a second, broad rule for replies: server port 443 to any high port
- An attacker can craft packets that look like replies

Stateful firewall (pf in pfSense and OPNsense)

- Records each allowed connection in the **state table**
- Replies match the table and pass without any rule
- A **SYN-ACK** (Synchronize-Acknowledgment) that matches no entry is dropped; idle entries time out

1. SYN

2. SYN-ACK

3. ACK

TCP (Transmission Control Protocol) three-way handshake followed by the firewall

Write rules only for the direction in which a connection is opened. The state table handles the replies.

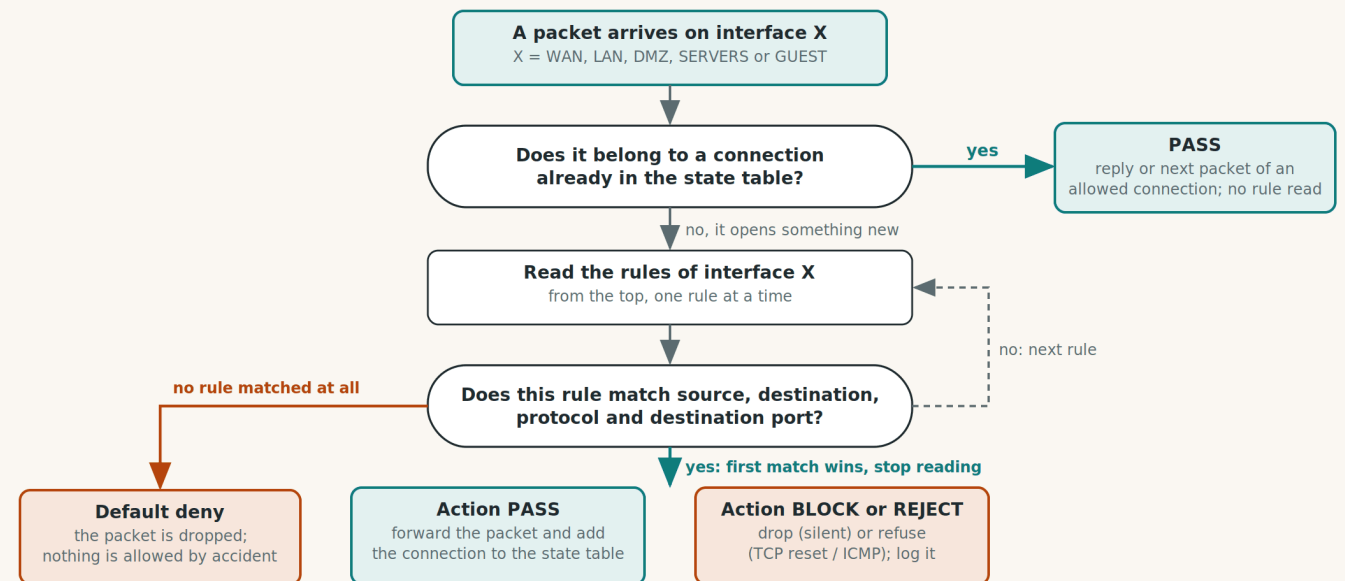
1

First match and default deny

- Rules of the **arrival interface** are read from the top.
- A rule matches when every field it specifies fits the packet.
- The **first match** decides; no lower rule is read.
- No match at all: **default deny** drops the packet.
- Same behaviour on pfSense and OPNsense (pf engine).

How a stateful firewall decides the fate of one packet

The same procedure runs for every packet on every interface of NM-FW01, wired or wireless.



Abbreviations: WAN (Wide Area Network); LAN (Local Area Network); DMZ (Demilitarized Zone); TCP (Transmission Control Protocol); ICMP (Internet Control Message Protocol).

1

Three actions: pass, block, reject

Pass

- Forwards the packet and creates a state entry
- The test sees: success, if a service listens
- Use: every flow of the zoning table

Block

- Drops the packet silently
- The test sees: a timeout
- Use: the **WAN** (Wide Area Network) interface; explicit denies you want to log

Reject

- Drops it and answers with a **TCP** (Transmission Control Protocol) reset or an **ICMP** (Internet Control Message Protocol) unreachable message
- The test sees: an immediate refusal
- Use: internal interfaces, to fail fast

Default deny behaves like block. Turn on logging for the blocks you care about: a logged block is your evidence in Chapter 5.

1

Two installation defaults to fix today

1

Anti-lockout rule (LAN)

- Keeps the web interface reachable from the whole LAN
- In Class 11 you limited management to NM-LWS01
- Narrow or remove it only after your own management rule is tested

2

Default rule "LAN net to any"

- Lets every workstation reach every zone
- Contradicts your zoning table
- Replace it with the specific rules of Lesson 2

Safe order of work

1. Create the NM-LWS01 management rule

2. Test it from NM-LWS01

3. Then remove the broad defaults



1

Wired zones: a dedicated interface or a VLAN

A

Dedicated interface

- One firewall network card per zone
- Cabled to the switch of that zone
- Simple to read; needs one port per zone

B

VLAN (Virtual Local Area Network) on a shared link

- Each frame carries an 802.1Q tag with the VLAN number
- **Access port:** one VLAN, tag removed before the computer
- **Trunk:** several tagged VLANs between switch and firewall

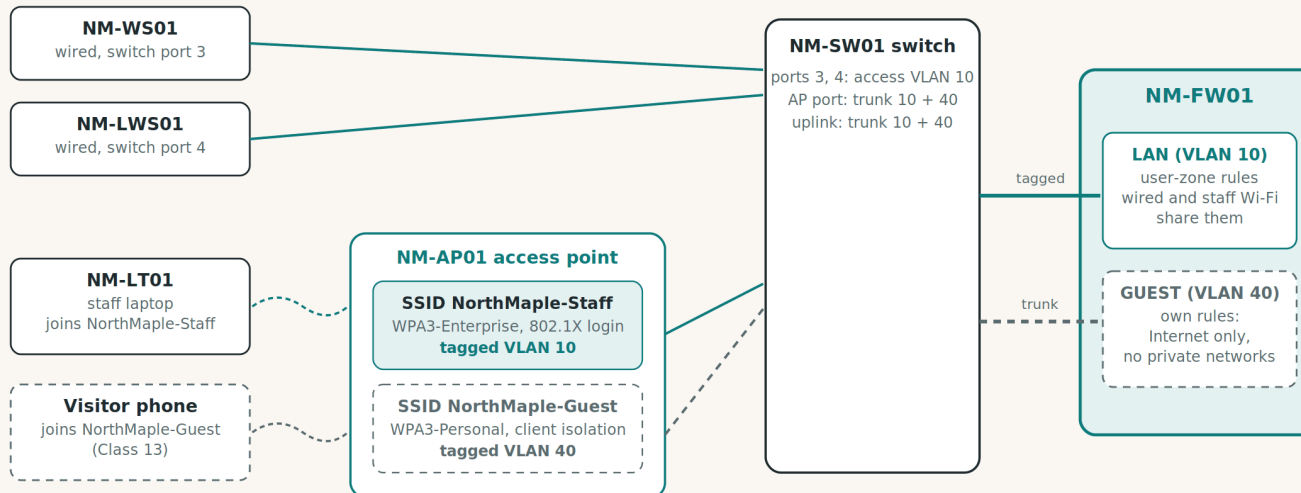
On the firewall, each VLAN is its own interface with its own rules. In a virtual lab, one virtual network per zone gives the same result.

A machine belongs to a zone because of the interface or VLAN it is connected to.

1 Wireless: two decisions at two places

Wired and wireless traffic reach NM-FW01 the same way: through a VLAN interface

The security decision for Wi-Fi is made twice: at the access point (who may join the SSID) and at the firewall (what the client may reach).



Abbreviations: VLAN (Virtual Local Area Network); SSID (Service Set Identifier); WPA3 (Wi-Fi Protected Access 3); AP (Access Point); LAN (Local Area Network); 802.1X is the IEEE (Institute of Electrical and Electronics Engineers) port-based access-control standard.

Access point NM-AP01

Decides who joins the **SSID** (Service Set Identifier): **WPA3-Enterprise** (Wi-Fi Protected Access 3, Enterprise mode) (802.1X, one account per person) or **WPA3-Personal** (Wi-Fi Protected Access 3, Personal mode) (**SAE** (Simultaneous Authentication of Equals) passphrase)

Firewall NM-FW01

Decides what a client may reach: staff SSID on **VLAN** (Virtual Local Area Network) 10 meets the **LAN** (Local Area Network) rules

A strong passphrase does not replace rules; rules do not protect a radio link that anyone can join.

1

Guest Wi-Fi and egress filtering

G

Guest SSID (Service Set Identifier), added at Class 13

- Own **VLAN** (Virtual Local Area Network) and its own GUEST interface
- Rules: Internet allowed, every private network blocked
- **Client isolation** on the access point: guests cannot reach each other
- Optional **captive portal** showing the terms of use
- Access point management reachable only from NM-LWS01

E

Egress filtering: both directions

- Filter traffic that leaves a zone, not only traffic that enters
- User zone: **HTTPS** (Hypertext Transfer Protocol Secure) to the Internet, **DNS** (Domain Name System) to NM-FW01 only
- Malware cannot choose any port to contact its operator
- Nobody bypasses the company resolver
- Written on the interface of the internal zone, where the traffic enters

1

Watch: videos for Lesson 1



Firewall Types, SY0-701 objective 3.2

Professor Messer. Network firewalls, **NGFW** (Next-Generation Firewall), **UTM** (Unified Threat Management) and **WAF** (Web Application Firewall): what each type inspects. Watch how the inspection depth changes the decisions a firewall can make.

Video: <https://www.youtube.com/watch?v=mq1HRM-zGtQ>

Transcript: <https://www.professormesser.com/security-plus/sy0-701/sy0-701-video/firewall-types-sy0-701/>



Wireless Security Settings, SY0-701 objective 4.1

Professor Messer. **WPA3** (Wi-Fi Protected Access 3), **SAE** (Simultaneous Authentication of Equals), 802.1X, **RADIUS** (Remote Authentication Dial-In User Service) and **EAP** (Extensible Authentication Protocol): the access-point side of the two wireless decisions described in section 1.5.

Video: <https://www.youtube.com/watch?v=KaqKokNEKnE>

Transcript: <https://www.professormesser.com/security-plus/sy0-701/sy0-701-video/wireless-security-settings-sy0-701/>

TikTok, by hashtag only (no direct links in this course): #firewallrules #statefulfirewall #opnsense #pfsense #wifisecurity #wpa3

Before trusting a clip: who published it? Does it show a real appliance? Does it agree with the official documentation? Does it stay inside your own lab?

1

Example 1: ten packets at NM-FW01 on a Monday morning

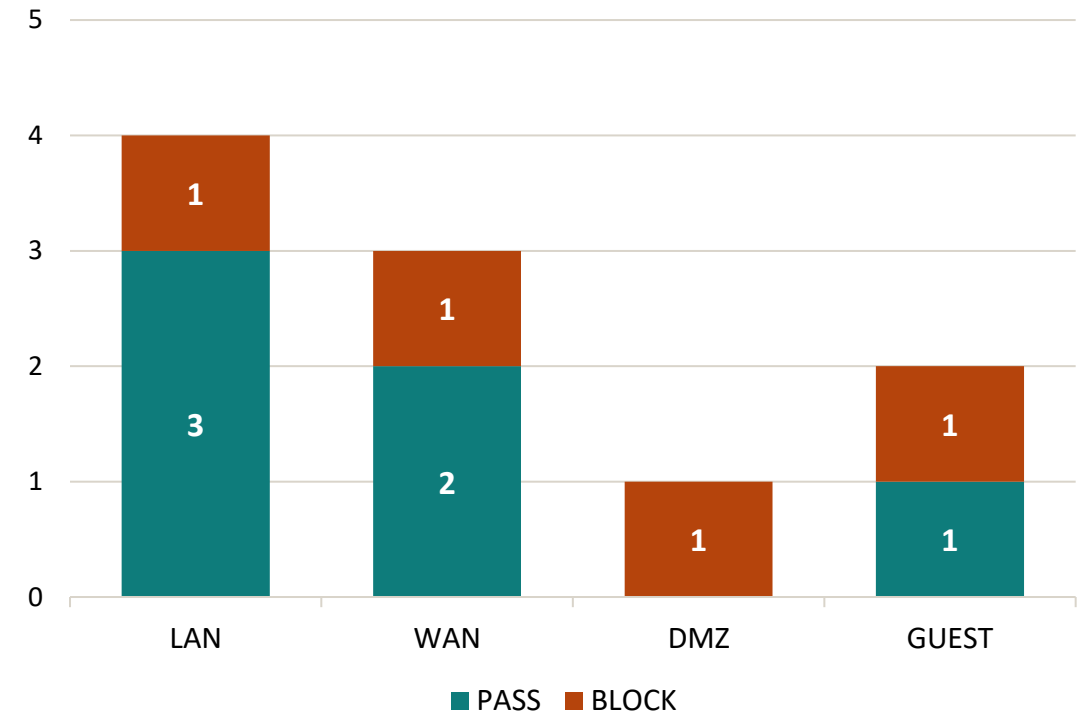
The task

Predict, then verify, NM-FW01's decision for ten packets from a wired **PC** (Personal Computer), a staff laptop on Wi-Fi, the Internet, the **DMZ** (Demilitarized Zone) and a future guest phone.

- Write PASS or BLOCK for P1 to P10, and the deciding rule
- Run the simulation in the lecture page, step by step
- Pause on P2: which mechanism lets the reply in?
- Pause on P6: why does LAN-2 decide before LAN-5?

Reused in LAB_05: your predictions next to the observed results become the model of the validation table.

Decisions by arrival interface (10 packets)



P2: state table

P6: LAN-2 first

P3: default deny

2

Lesson 2 of 4, about 14 minutes

Translating the zoning design of LAB_01 into real firewall rules between zones

In this lesson

- The zoning table as a specification
- Seven steps from a zoning row to a rule
- Ingress placement and rule order against shadowing
- Allowed and blocked tests, and how to read their results

2

The zoning table is the specification

Row	Source zone	Source	Destination	Service	Action
Z1	Internet	any	NM_WEB01	tcp/443	ALLOW
Z2	User zone	LAN_NET	NM_FS01	tcp/445	ALLOW
Z3	User zone	LAN_NET	!PRIVATE	tcp/443	ALLOW
Z4	User zone	LAN_NET	NM_FW01	udp/53	ALLOW
Z5	User zone	NM_LWS01	NM_FW01	tcp/443,22	ALLOW
Z6	User zone	NM_LWS01	NM_FS01	tcp/22	ALLOW
Z7	Server zone	SRV_NET	!PRIVATE	tcp/443	ALLOW
Z8	DMZ (Demilitarized Zone)	DMZ_NET	!PRIVATE	tcp/443	ALLOW
Z9	DMZ	DMZ_NET	PRIVATE	any/any	DENY
Z10	Internet	any	INTERNAL_NETS	any/any	DENY
Z11	User zone	LAN_NET	NM_FW01	tcp/443,22	DENY
Z12	DMZ	DMZ_NET	NM_FW01_DMZ	udp/53	ALLOW

Justifications are in the lecture page (Table 3) and in t_zoning.csv. !PRIVATE means "any address outside the **RFC** (Request for Comments) 1918 ranges", which is the Internet.

2 Seven steps from a zoning row to a rule (1/2)

1

Map each zone to an interface

Internet to **WAN** (Wide Area Network), user zone to **LAN** (Local Area Network), **DMZ** (Demilitarized Zone) to DMZ, server zone to SERVERS; rename OPT1 and OPT2 with zone names.

2

Create aliases

Hosts NM_WEB01, NM_FS01, NM_LWS01, NM_FW01; networks LAN_NET, DMZ_NET, SRV_NET; PRIVATE = the three **RFC** (Request for Comments) 1918 ranges.

3

Place each rule on the ingress interface

The interface where the traffic enters: the source zone's interface. Z2 lives on LAN, not on SERVERS.

4

Write the narrowest rule

Protocol, source, destination and port. "The Internet" is destination not PRIVATE, never any.

2 Seven steps from a zoning row to a rule (2/2)

5

Order the rules on each interface

Management from NM-LWS01 first, then narrow allows, explicit blocks, broad allows.

6

Write the description

Start with the zoning row: "Z2 Accountants open client records". Rule and row then point to each other.

7

Publish the DMZ (Demilitarized Zone) service

Port forward **WAN** (Wide Area Network) 443 to 192.168.20.10; the WAN rule names NM_WEB01, because filtering happens after **NAT** (Network Address Translation).

LAN interface, evaluation order

1. Z5 pass tcp/443,22

2. Z2 pass tcp/445

3. Z4 pass udp/53

4. Z6 pass tcp/22

5. Z11 block tcp/443,22

6. Z3 pass tcp/443

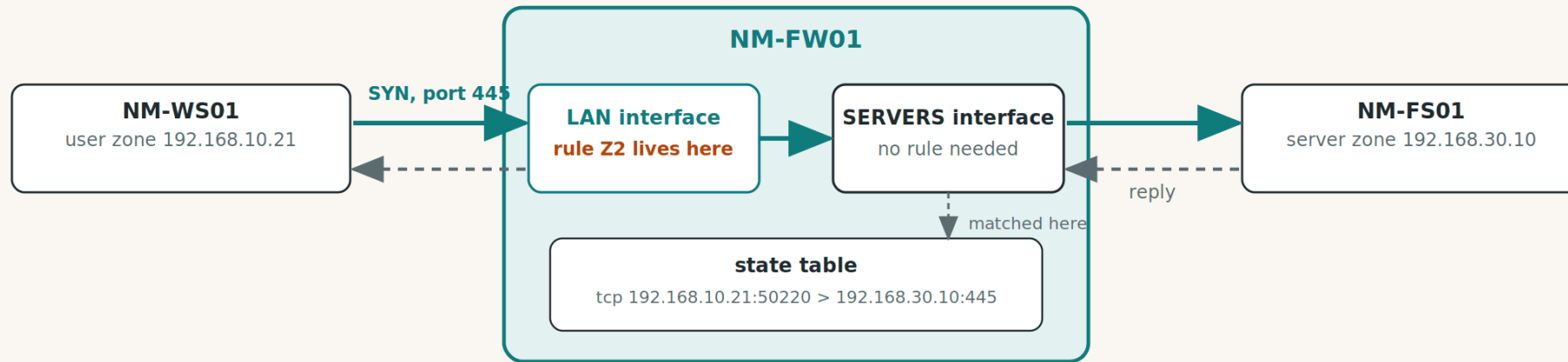
7. default deny

2

Place the rule where the traffic enters

Where a rule goes: on the interface where the traffic ENTERS the firewall

Zoning row Z2 (user zone to the file server, SMB 445) becomes one pass rule on LAN. The reply needs no rule: the state table returns it.



Rule text as it appears in the rule set:

Interface LAN | pass | TCP | source LAN_NET | destination NM_FS01 | port 445 | description "Z2 Accountants open client records ..."

Wrong placement: the same rule on SERVERS would never be read, because the request does not enter the firewall there.

Abbreviations: LAN (Local Area Network); TCP (Transmission Control Protocol); SYN (Synchronize); SMB (Server Message Block).

Request enters on LAN: the rule is on LAN

A rule on SERVERS is never read for it

The reply returns by the state table

2

Specific before general: avoiding rule shadowing

Wrong order on DMZ (Demilitarized Zone)

1. Z9 block DMZ_NET to PRIVATE, any

2. Z12 pass to NM_FW01_DMZ, udp/53

Z12 is never read: 192.168.20.1 is a private address, so Z9 always matches first.

The web server cannot resolve names; its updates fail silently.

Right order on DMZ

1. Z12 pass to NM_FW01_DMZ, udp/53

2. Z9 block DMZ_NET to PRIVATE, any

3. Z8 pass to !PRIVATE, tcp/443

4. default deny

A shadowed rule exists in the list but never acts. Check every narrow allow against the blocks placed above it.

2 Prove every rule: positive and negative tests

- **Positive test:** proves an allowed flow works, from a machine in the source zone.
- **Negative test:** proves a forbidden flow, or a port the rule must not open, is blocked.
- Record four things per test:

Command and machine

Expected result

Observed result

Evidence (screenshot, log line)

Linux

```
nc -zv -w 3 192.168.30.10 445
```

Windows

```
Test-NetConnection 192.168.30.10 -Port 445
```

Name resolution test

```
nslookup www.northmaple.lab 192.168.10.1
```

Firewall log

OPNsense: Firewall, Log Files, Live View
pfSense: Status, System Logs, Firewall

2

Reading a test result

What you observe	What it usually means	Positive test	Negative test
Succeeded (TcpTestSucceeded : True)	Passed, and a service answered	PASS	FAIL: rule too wide
Timeout	Dropped: block, default deny or host firewall	FAIL: find the missing rule	PASS with the block in the log
Refused, immediately	Reject rule, or nothing listens on the host	FAIL: service down or reject	PASS only with a reject line
Name resolved (nslookup)	DNS (Domain Name System) reached the resolver	PASS	FAIL: resolver reachable

The firewall log decides. Keep its line with every negative test.
Positive test failing? Check the host firewall of LAB_03 too.

2 Seven mistakes found in most first rule sets

×

An "any to any" rule left from the installation

×

A rule on the destination interface instead of the ingress interface

×

"any" used where "the Internet" was meant

×

A missing **DNS** (Domain Name System) rule: every web test fails

×

A narrow rule shadowed by a broad one above it

×

Blocks without logging: no evidence

×

Descriptions that say "test" instead of the zoning row

Chapter 5 grading: 1.0 exists and works, 0.5 validated, 0.5 justified

2

Watch: videos for Lesson 2



Firewalls, SY0-701 objective 4.5

Professor Messer. Top-down rule evaluation, implicit deny, a worked rule base and the screened subnet (DMZ). Pause on the rule table and predict each decision.

Video: <https://www.youtube.com/watch?v=VgNyh4HEqSU>

Transcript: <https://www.professormesser.com/security-plus/sy0-701/sy0-701-video/firewalls-sy0-701/>



Secure Infrastructures, SY0-701 objective 3.2

Professor Messer. Security zones, trusted and untrusted networks, and device placement: the design your zoning table encodes.

Video: <https://www.youtube.com/watch?v=I64La1xYXL4>

Transcript: <https://www.professormesser.com/security-plus/sy0-701/sy0-701-video/secure-infrastructures-sy0-701/>

TikTok, by hashtag only (no direct links in this course): #networksegmentation #dmz #firewallrules #zerotrust #netsec

Before trusting a clip: who published it? Does it show a real appliance? Does it agree with the official documentation? Does it stay inside your own lab?

Example 2: from zoning rows to rule set and test plan

The task

Convert the twelve zoning rows into an ordered rule set per interface, check traceability, and generate the allowed and blocked tests of LAB_05.

- Replace the ZONING rows with your Class 2 rows
- Run the script; read why Z12 comes before Z9
- Create the rules in the order of LAB05_rule_set.csv
- Run each test of LAB05_test_plan.csv and fill observed and evidence

12

zoning rows translated

12

rules, plus default deny on 4 interfaces

17

tests: 10 ALLOW, 7 BLOCK

0

zoning rows without a rule

Reused in Chapter 5: both **CSV** (Comma-Separated Values) files, completed with your observations, are the rule-set and validation evidence.

The generated rule set, interface by interface

WAN interface

1. **Z1 pass tcp/443**
to NM_WEB01
2. **Z10 block any/any**
to INTERNAL_NETS
3. **default deny**

LAN interface

1. **Z5 pass tcp/443,22**
to NM_FW01
2. **Z2 pass tcp/445**
to NM_FS01
3. **Z4 pass udp/53**
to NM_FW01
4. **Z6 pass tcp/22**
to NM_FS01
5. **Z11 block tcp/443,22**
to NM_FW01
6. **Z3 pass tcp/443**
to !PRIVATE
7. **default deny**

DMZ interface

1. **Z12 pass udp/53**
to NM_FW01_DMZ
2. **Z9 block any/any**
to PRIVATE
3. **Z8 pass tcp/443**
to !PRIVATE
4. **default deny**

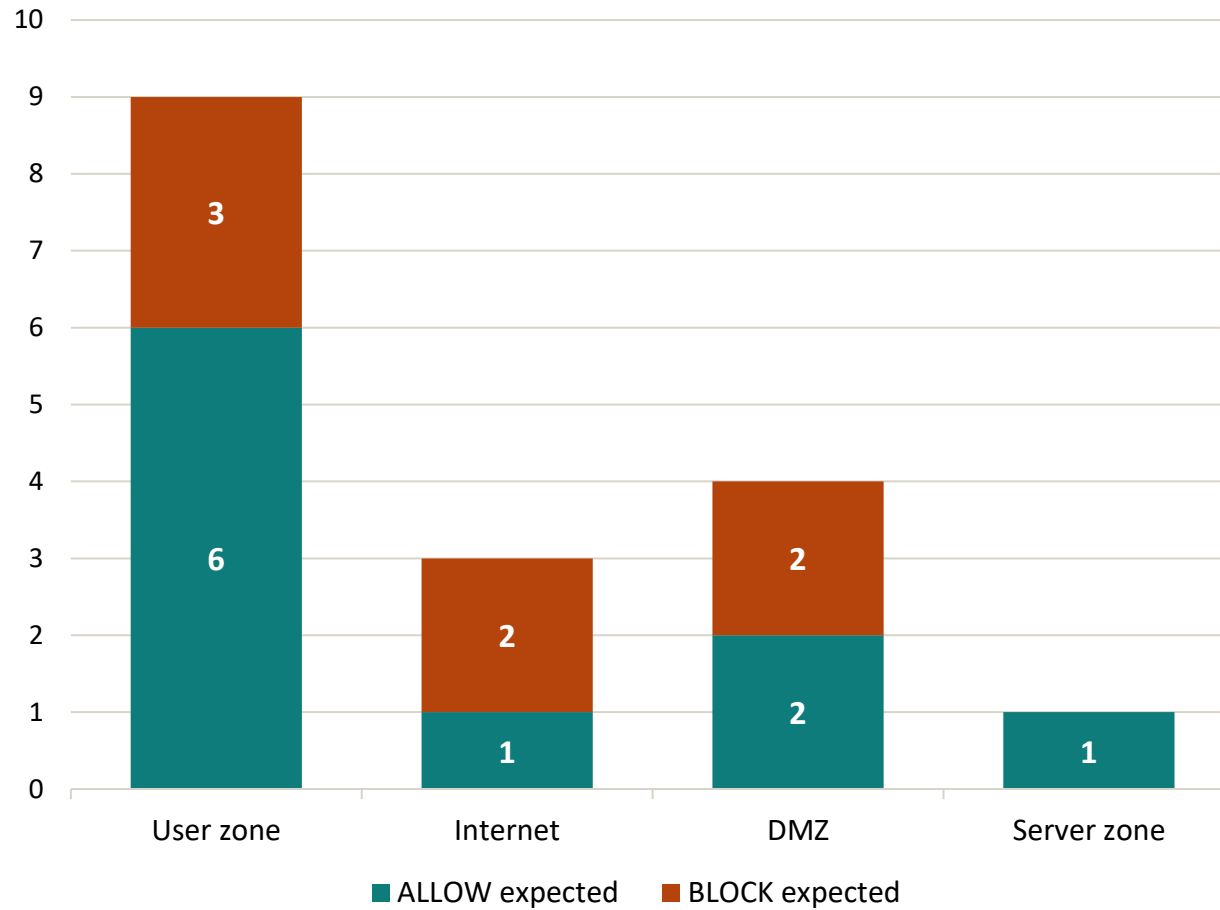
SERVERS interface

1. **Z7 pass tcp/443**
to !PRIVATE
2. **default deny**

2

The test plan at a glance

Tests by source zone (17 tests)



T05 (Z2) from NM-WS01: expect ALLOW

```
Test-NetConnection 192.168.30.10 -Port 445
```

T06 (Z2-neg) from NM-WS01: expect BLOCK

```
Test-NetConnection 192.168.30.10 -Port 22
```

T13 (Z11) from NM-WS01: expect BLOCK

```
Test-NetConnection 192.168.10.1 -Port 443
```

2 Zone-to-zone matrix of the reference design

Zone-to-zone matrix of the reference zoning table (source row, destination column)

Every allowed cell names its zoning row; every empty cell is closed by default deny. The table is the specification, the rules are its translation.

		destination zone				
		Internet	DMZ	User zone	Server zone	Firewall
source	Internet	same zone	Z1 HTTPS 443 to NM-WEB01 only	Z10 blocked, logged	Z10 blocked, logged	default deny
	DMZ	Z8 HTTPS 443 (updates)	same zone	Z9 blocked, logged	Z9 blocked, logged	Z12 DNS 53 only
	User zone	Z3 HTTPS 443	default deny	same zone	Z2 SMB 445 Z6 SSH 22 (admin)	Z4 DNS 53 Z5 mgmt (admin) Z11 others blocked
	Server zone	Z7 HTTPS 443 (updates)	default deny	default deny	same zone	default deny
		 allowed by a zoning row (pass rule on the source interface)	 explicit, logged block rule	 closed by the implicit default deny		

Abbreviations: DMZ (Demilitarized Zone); HTTPS (Hypertext Transfer Protocol Secure); SMB (Server Message Block); SSH (Secure Shell); DNS (Domain Name System).

3

Lesson 3 of 4, about 13 minutes

Session hijacking prevention and cache protection (introductory level)

In this lesson

- What a session identifier is, and how it is stolen
- Six controls at the application and transport level
- The **ARP** (Address Resolution Protocol), **DNS** (Domain Name System) and web caches, and how each is protected
- A read-only check you can run in your own lab

3

How a session works, and what hijacking takes

1. Login

Password, and a second factor if required



2. Server

Creates a random session identifier and stores it with the user



3. Set-Cookie

The identifier travels to the browser in a cookie



4. Every request

The browser returns the cookie; no password is asked

Session hijacking: whoever presents the identifier is treated as the user.

Multi-factor authentication does not help afterwards: the cookie is issued after the login step.

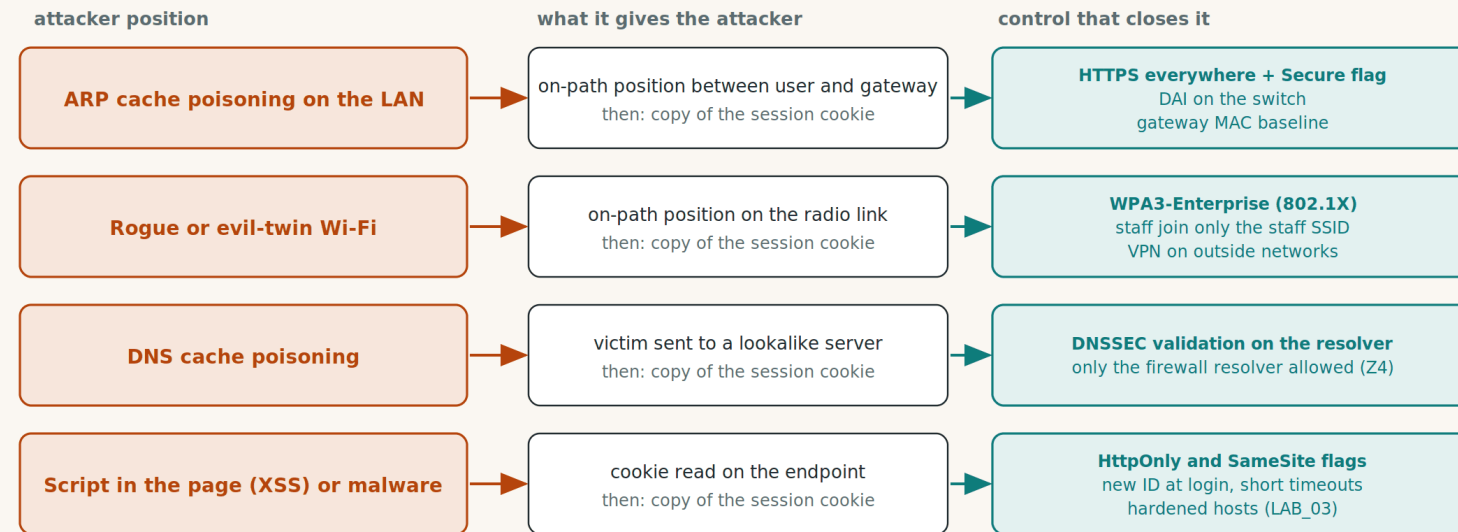
Older network-level hijacking predicted **TCP** (Transmission Control Protocol) sequence numbers. Random initial sequence numbers and encryption make it rare today; attackers now aim at the cookie.

3

Four paths to a session identifier

Four ways to obtain a session identifier, and the control that closes each one

An attacker who presents a valid session cookie is treated by the server as the logged-in user. Remove the ways to read or steal it.



Abbreviations: ARP (Address Resolution Protocol); LAN (Local Area Network); HTTPS (Hypertext Transfer Protocol Secure); DAI (Dynamic ARP Inspection); MAC (Media Access Control); SSID (Service Set Identifier); WPA3 (Wi-Fi Protected Access 3); VPN (Virtual Private Network); DNS (Domain Name System); DNSSEC (DNS Security Extensions); XSS (Cross-Site Scripting); ID (Identifier).

- **On-path: ARP** (Address Resolution Protocol) poisoning on the **LAN** (Local Area Network), or a rogue access point
- **DNS (Domain Name System) poisoning**: a lookalike server collects the login
- **XSS (Cross-Site Scripting)**: a script in the page reads the cookie
- **Infected endpoint**: malware reads it locally
- **Session fixation**: the attacker imposes a known identifier

3

Six controls against session hijacking

1

HTTPS (Hypertext Transfer Protocol Secure) on every page

TLS (Transport Layer Security) encrypts the whole request, cookie included

2

Secure attribute

The cookie is never sent over plain **HTTP** (Hypertext Transfer Protocol)

3

HSTS (HTTP Strict Transport Security) header

The browser refuses plain HTTP for the site

4

HttpOnly attribute

Scripts in the page cannot read the cookie

5

SameSite Lax or Strict

Not attached to requests started by other sites; reduces **CSRF** (Cross-Site Request Forgery)

6

New ID (Identifier) and timeouts

New identifier at login; idle and absolute timeouts; logout destroys the session

3 Cookie attributes and security headers

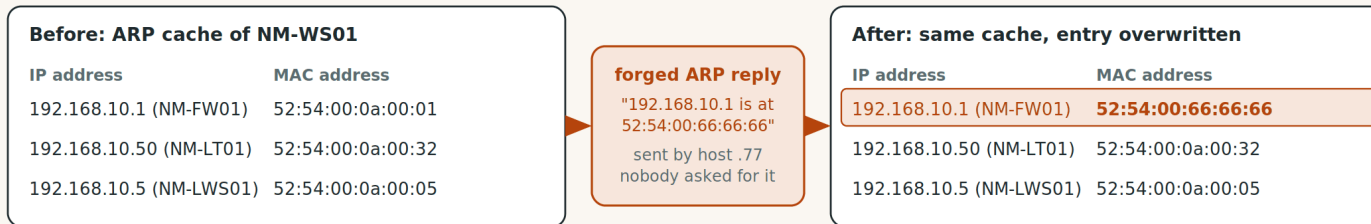
Setting	Where it is set	What it prevents	Example 3
Secure	Set-Cookie attribute	Cookie sent over unencrypted HTTP (Hypertext Transfer Protocol) and read on the path	Yes (FAIL if missing)
HttpOnly	Set-Cookie attribute	Cookie read by a script in the page (XSS)	Yes (FAIL if missing)
SameSite=Lax or Strict	Set-Cookie attribute	Cookie attached to requests started by other sites (CSRF)	Yes (WARN if missing)
Strict-Transport-Security (HSTS)	Response header	Downgrade of the first connection to plain HTTP	Yes (WARN if missing)
Cache-Control: no-store	Response header	Authenticated page kept by the browser or a shared cache	Yes (WARN if missing)
New ID (Identifier) after login, idle and absolute timeouts	Application logic on the server	Fixation; long use of a stolen identifier	No (review the application)

Sources: **RFC** (Request for Comments) 6265 (cookies), RFC 6797 (HSTS), RFC 9111 (HTTP caching), **OWASP** (Open Worldwide Application Security Project) Session Management Cheat Sheet.

ARP cache poisoning and its defenses

ARP cache poisoning: one forged reply rewrites the cache of NM-WS01

ARP has no authentication: a host accepts a reply that nobody asked for and overwrites the entry. The next packets for the gateway go to the attacker.



Defenses that remove or reveal the forged entry

1. Dynamic ARP Inspection (DAI) on a managed switch drops ARP replies that do not match the DHCP snooping bindings.
2. A static ARP entry for the gateway on critical hosts (for example NM-LWS01) ignores forged replies for that one address.
3. Monitoring: compare the gateway MAC with the device-registry baseline; alert when one MAC claims two IP addresses (Example 3).
4. Encryption: with HTTPS and the Secure cookie flag, an on-path host sees only encrypted data, never the session cookie.
5. Segmentation: poisoning only reaches hosts in the same broadcast domain, so smaller zones limit the reach of one infected host.

Abbreviations: ARP (Address Resolution Protocol); IP (Internet Protocol); MAC (Media Access Control); DAI (Dynamic ARP Inspection); DHCP (Dynamic Host Configuration Protocol); HTTPS (Hypertext Transfer Protocol Secure).

- **ARP** (Address Resolution Protocol) has no authentication: forged replies overwrite the gateway entry.
- **DAI (Dynamic ARP Inspection)** on the switch drops replies that do not match **DHCP** (Dynamic Host Configuration Protocol) snooping bindings.
- Static gateway entry on NM-LWS01.
- Compare with the gateway **MAC** (Media Access Control) in the device registry.
- **HTTPS** (Hypertext Transfer Protocol Secure) and Secure: the on-path host sees no cookie.
- Zoning: ARP cannot cross NM-FW01.

3

DNS cache poisoning and four controls

A resolver keeps each answer for its **TTL (Time To Live)**. One forged answer sends every client to a lookalike server until the entry expires.

1

DNSSEC (Domain Name System Security Extensions) validation

Signatures are checked before caching; validated answers carry the **AD** (Authenticated Data) flag (Unbound).

2

Randomisation

Random source ports and query identifiers; keep the resolver updated.

3

No open resolver

The resolver answers internal clients only, never the Internet.

4

One enforced resolver

Rule Z4: workstations send **DNS** (Domain Name System) to NM-FW01 only.



3 Web caches and the three caches compared

Authenticated pages send **Cache-Control: no-store** (RFC (Request for Comments) 9111): no browser or shared cache keeps a copy. Public pages may be cached normally.

Cache	What it stores	How it is abused	Main protections at NorthMaple
ARP (Address Resolution Protocol) cache (every host)	IP (Internet Protocol) address to MAC (Media Access Control) address on the local network	Forged ARP replies redirect traffic to an on-path host	DAI (Dynamic ARP Inspection) with DHCP (Dynamic Host Configuration Protocol) snooping; static gateway entry on NM-LWS01; MAC baseline in the registry; zoning; HTTPS (Hypertext Transfer Protocol Secure)
DNS (Domain Name System) cache (resolver on NM-FW01)	Name to IP address, for the TTL (Time To Live) of each record	Forged answer sends every client to a lookalike server	DNSSEC (Domain Name System Security Extensions) validation; random ports and IDs (Identifiers); no open resolver; rule Z4 enforces one resolver
Web cache (browser, proxy)	Copies of pages and resources	Stored authenticated pages disclose client data	Cache-Control: no-store on authenticated pages; logout clears the session



3

Watch: videos for Lesson 3



Replay Attacks, SY0-701 objective 2.4

Professor Messer. Session **IDs** (Identifiers), cookies and session hijacking (sidejacking), with the defense of encrypting the whole session.

Video:

<https://www.youtube.com/watch?v=ai6qS13gKRo>

Transcript:

<https://www.professormesser.com/security-plus/sy0-701/sy0-701-video/replay-attacks-sy0-701/>



On-path Attacks, SY0-701 objective 2.4

Professor Messer. How **ARP** (Address Resolution Protocol) poisoning places an attacker on the path between a host and its gateway, and the on-path browser variant.

Video:

https://www.youtube.com/watch?v=M_Af6_8JTuo

Transcript:

<https://www.professormesser.com/security-plus/sy0-701/sy0-701-video/on-path-attacks-sy0-701/>



DNS (Domain Name System) Attacks, SY0-701 objective 2.4

Professor Messer. DNS poisoning of a resolver, domain hijacking and **URL** (Uniform Resource Locator) hijacking: why a validated, controlled resolver matters.

Video:

<https://www.youtube.com/watch?v=BoxeL5ybOXI>

Transcript:

<https://www.professormesser.com/security-plus/sy0-701/sy0-701-video/dns-attacks-sy0-701/>

TikTok, by hashtag only (no direct links in this course): #sessionhijacking #arpspoofing #dnssec #cookiesecurity #websecurity

Before trusting a clip: who published it? Does it show a real appliance? Does it agree with the official documentation? Does it stay inside your own lab?



3

Example 3: is Marc's session safe?

The task

From NM-LWS01, run three read-only checks: the **ARP** (Address Resolution Protocol) cache, **DNSSEC** (Domain Name System Security Extensions) validation by the firewall's resolver, and the cookie and cache headers of the internal **HTTPS** (Hypertext Transfer Protocol Secure) service.

- **ip -4 neigh show**: gateway **MAC** (Media Access Control) and duplicates
- **dig +dnssec**: the **AD** (Authenticated Data) flag
- **curl -D -**: Set-Cookie and security headers
- Live mode runs only against private (**RFC** (Request for Comments) 1918) addresses

Reused in LAB_06 (Class 17): the live report becomes validation evidence of Chapter 6.

ARP gateway MAC

FAIL

ARP duplicate MAC

FAIL

DNSSEC (AD flag)

PASS

Cookie Secure

FAIL

Cookie HttpOnly

PASS

Cookie SameSite

WARN**HSTS** (HTTP Strict Transport Security)**WARN**

no-store

PASS**FAIL**

Overall verdict of the demo: 3 fail, 2 warn, exit code 1

4

Lesson 4 of 4, about 11 minutes

DoS attack defense strategies: basic, practical measures

In this lesson

- Availability, **DoS** (Denial-of-Service) and **DDoS** (Distributed Denial-of-Service)
- Three classes, by the resource they exhaust
- Practical measures for a small company, layer by layer
- The common triage sequence, explained in theory

4 Three classes of DoS attack

DoS (Denial-of-Service) makes a service unavailable by exhausting a resource; **DDoS (Distributed Denial-of-Service)** does it from many sources at once, often a botnet (Class 4 malware families).

Class	Resource exhausted	Unit that grows	Typical example	Layer that absorbs it
Volumetric	Capacity of the WAN (Wide Area Network) link	Bits per second	UDP (User Datagram Protocol) reflection and amplification (DNS (Domain Name System), NTP (Network Time Protocol))	Upstream: provider, mitigation service, CDN (Content Delivery Network)
Protocol / state exhaustion	State table of the firewall; half-open queue of the server	Packets per second	SYN (Synchronize) flood	NM-FW01 and the server's TCP (Transmission Control Protocol) stack
Application layer	Processor, memory, worker processes of the service	Requests per second	HTTP (Hypertext Transfer Protocol) flood; very slow requests	NM-WEB01 (and a CDN in front of it)

Distributed describes the number of sources, not the class.



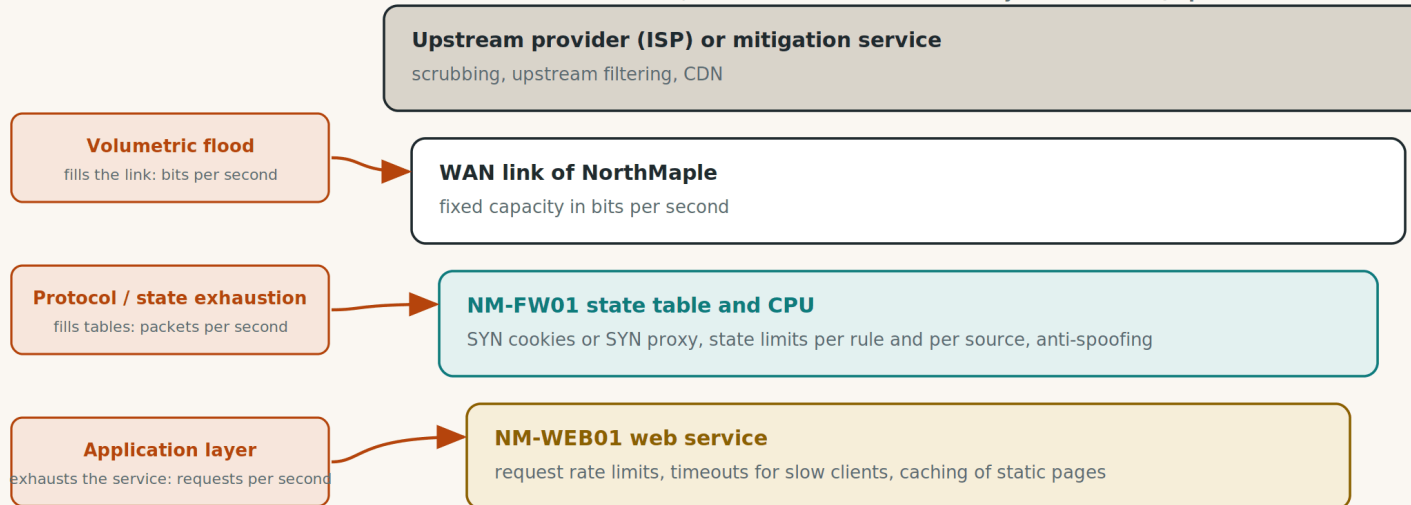
Where each class hits the network

Where each class of denial-of-service attack is absorbed

A defense works only at or before the resource the attack exhausts. A firewall cannot help once the WAN link itself is full.

attack class

resource each class exhausts; the defense must sit at that layer or above it (top = first to see the traffic)



Abbreviations: ISP (Internet Service Provider); CDN (Content Delivery Network); WAN (Wide Area Network); CPU (Central Processing Unit); SYN (Synchronize).

- **Volumetric:** the link is full before NM-FW01 sees a packet; only the provider can filter.
- **Reflection and amplification:** small forged queries, large answers to the victim.
- **SYN (Synchronize) flood:** half-open connections fill tables.
- **Application layer:** valid-looking requests exhaust the service.

4

Practical measures for a small company (1/2)

1

Know your baseline

Normal bandwidth, packets per second, states in the firewall table, requests per second on NM-WEB01.

2

Keep the attack surface small

Zoning row Z1 publishes one service: **HTTPS** (Hypertext Transfer Protocol Secure) on NM-WEB01. What is not published cannot be flooded directly.

3

Limit states on the publishing rule

Maximum states, states per source, new connections per source (next slide).

4

Protect the TCP (Transmission Control Protocol) handshake

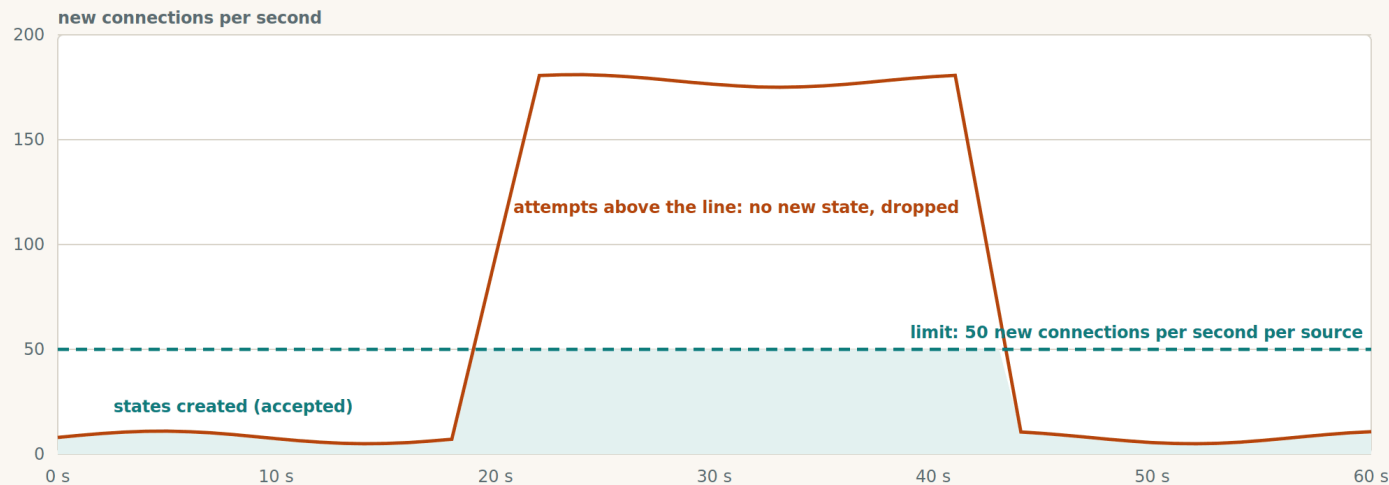
SYN (Synchronize) cookies on the server, a SYN proxy where the appliance offers one, shorter half-open timeouts (**RFC** (Request for Comments) 4987).

4

Limit states per source on the publishing rule

Per-source limit on the DMZ publishing rule (illustrative data)

New connections per second from one address toward NM-WEB01:443. Above the limit, the firewall stops creating states for that source.



The numbers are illustrative, chosen for teaching; measure your own baseline before choosing any limit.
Option names for state and connection limits vary by appliance version (VERIFY BEFORE CLASS).

Abbreviations: DMZ (Demilitarized Zone).

- Caps on the Z1 pass rule: total states, states per source, new connections per second per source.
- An abusive source is refused new states; other visitors continue.
- Set the values from your baseline.
- Does not stop many sources each below the limit, or a volumetric flood.
- Option names: VERIFY BEFORE CLASS.

4

Practical measures for a small company (2/2)

5

Filter spoofed addresses in both directions

WAN (Wide Area Network): block private and bogon sources. Internal interfaces: only the zone's own network as source (**BCP** (Best Current Practice) 38).

6

Do not become a reflector

The firewall's resolver answers internal clients only; nothing is published without a zoning row.

7

Protect the service itself

Rate limits per client, timeouts for slow clients, caching; a hosting provider or **CDN** (Content Delivery Network) can absorb floods.

8

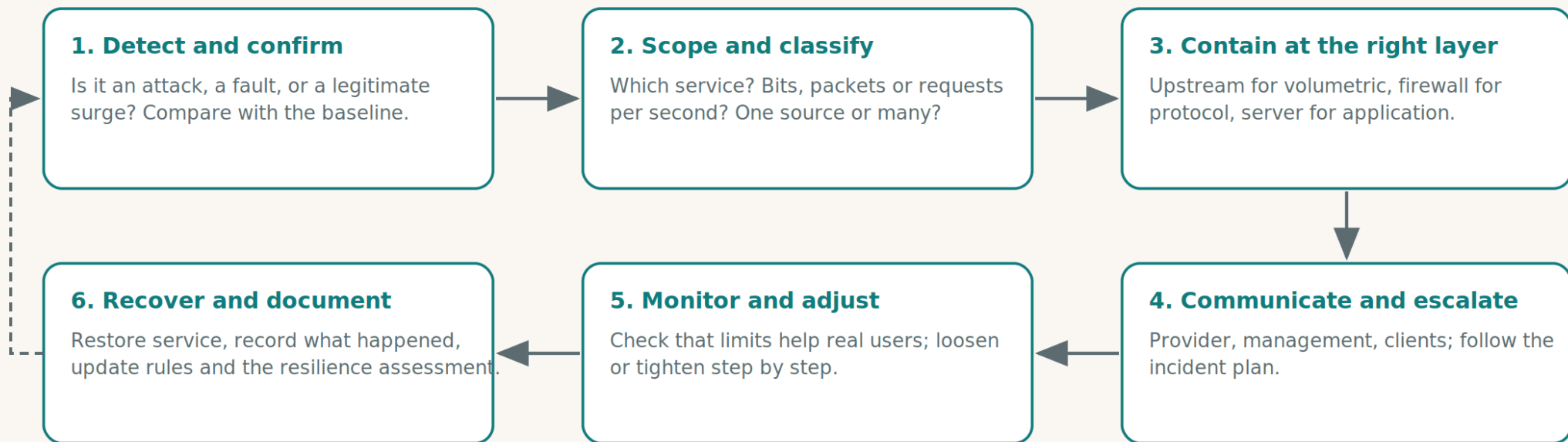
Prepare the upstream contact

The **ISP** (Internet Service Provider)'s **DDoS** (Distributed Denial-of-Service) contact, the mitigation in the contract, and who inside NorthMaple decides.

4 DoS triage: six stages, explained in theory

Common DoS triage sequence (theoretical model, no script by course decision)

Six stages that incident teams apply in this order. The last stage feeds the preparation for the next incident.



Stage 6 of a real incident becomes row 7 of your resilience assessment (Final Project, Chapter 7).

Abbreviations: DoS (Denial-of-Service).

Course decision: no DoS script. This sequence is explained, not automated.

Watch: videos for Lesson 4



Denial of Service, SY0-701 objective 2.4

Professor Messer. **DoS** (Denial-of-Service) and **DDoS** (Distributed Denial-of-Service), botnets, reflection and amplification, and the self-inflicted denial of service (switching loops).

Video: <https://www.youtube.com/watch?v=Z7OntvK--PQ>

Transcript: <https://www.professormesser.com/security-plus/sy0-701/sy0-701-video/denial-of-service-sy0-701/>



Understanding Denial-of-Service Attacks

CISA (Cybersecurity and Infrastructure Security Agency). Plain-language overview of DoS and DDoS (web page, not a video); the second address is **RFC** (Request for Comments) 4987 on **SYN** (Synchronize) floods and SYN cookies.

Page: <https://www.cisa.gov/news-events/news/understanding-denial-service-attacks>

Also: <https://www.rfc-editor.org/rfc/rfc4987>

TikTok, by hashtag only (no direct links in this course): #ddos #synflood #networksecurity #incidentresponse #availability

Before trusting a clip: who published it? Does it show a real appliance? Does it agree with the official documentation? Does it stay inside your own lab?

4

Example 4: the website stops answering at 9:05

Fictional scenario: tax season, clients call because the upload page does not load. Staff browsing is slow.

97%

state table of NM-FW01 is full,
mostly half-open to NM-
WEB01:443

1000s

of different source addresses

40%

of the **WAN** (Wide Area
Network) link is used

idle

processor of the web server

Classify: which resource is exhausted, and what does the idle processor tell you?

Locate: which layer can absorb this class? Which one if the link were at 100 percent?

Choose: which measures apply now, and which should have been prepared before?

Draft resilience row 7: defense layers, verdict, one sentence naming your configuration.

L LAB_05 part 2: what you build after the break

1

Create the rules that enforce your Class 2 zoning table: ingress interface, order, zoning **ID** (Identifier) in each description

2

Replace the broad **LAN** (Local Area Network) rule; keep management from NM-LWS01 working at every step

3

Validate every rule with allowed and blocked tests; capture the log line of each block

4

Complete the device registry: role, model or **VM** (Virtual Machine), version, management access, update status

Firewall rule set

Export or table, in evaluation order

Device registry

Every network device and appliance

Validation evidence

Command, expected, observed, screenshot, log line

LAB_05 = 5% of the course grade. Chapter 5 of the Final Project: 1.0 exists and works, 0.5 validated, 0.5 justified.
AI (Artificial Intelligence) rule: the model drafts; the analyst decides; the analyst's name goes on the record.

Official references and further reading (1/3)

Topic	Resource	Full address (click to open)
Course and safety	VirusTotal URL scanner	https://www.virustotal.com/gui/home/url
Firewalls	NIST SP 800-41 Rev. 1, Guidelines on Firewalls and Firewall Policy	https://csrc.nist.gov/pubs/sp/800/41/r1/final
Firewalls	OPNsense documentation: Firewall	https://docs.opnsense.org/manual/firewall.html
Firewalls	OPNsense documentation: Aliases	https://docs.opnsense.org/manual/aliases.html
Firewalls	Netgate pfSense documentation: Firewall	https://docs.netgate.com/pfsense/en/latest/firewall/index.html
Firewalls	CIS Critical Security Controls	https://www.cisecurity.org/controls
Wireless	NIST SP 800-153, Guidelines for Securing Wireless Local Area Networks	https://csrc.nist.gov/pubs/sp/800/153/final
Wireless	Wi-Fi Alliance: Security	https://www.wi-fi.org/discover-wi-fi/security
Wireless	OPNsense documentation: Captive Portal	https://docs.opnsense.org/manual/captiveportal.html
Addressing	RFC 1918, Address Allocation for Private Internets	https://www.rfc-editor.org/rfc/rfc1918
Addressing	RFC 5737, IPv4 Address Blocks Reserved for Documentation	https://www.rfc-editor.org/rfc/rfc5737
Sessions and caches	OWASP Session Management Cheat Sheet	https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html

Official references and further reading (2/3)

Topic	Resource	Full address (click to open)
Sessions and caches	OWASP HTTP Security Response Headers Cheat Sheet	https://cheatsheetseries.owasp.org/cheatsheets/HTTP-Headers-Cheat-Sheet.html
Sessions and caches	RFC 6265, HTTP State Management Mechanism (cookies)	https://www.rfc-editor.org/rfc/rfc6265
Sessions and caches	RFC 6797, HTTP Strict Transport Security	https://www.rfc-editor.org/rfc/rfc6797
Sessions and caches	RFC 9111, HTTP Caching	https://www.rfc-editor.org/rfc/rfc9111
Sessions and caches	RFC 826, An Ethernet Address Resolution Protocol	https://www.rfc-editor.org/rfc/rfc826
Sessions and caches	RFC 4033, DNS Security Introduction and Requirements	https://www.rfc-editor.org/rfc/rfc4033
Sessions and caches	OPNsense documentation: Unbound DNS	https://docs.opnsense.org/manual/unbound.html
Sessions and caches	MITRE ATT&CK T1557.002, ARP Cache Poisoning	https://attack.mitre.org/techniques/T1557/002/
Sessions and caches	MITRE ATT&CK T1539, Steal Web Session Cookie	https://attack.mitre.org/techniques/T1539/
Denial of service	CISA: Understanding Denial-of-Service Attacks	https://www.cisa.gov/news-events/news/understanding-denial-service-attacks
Denial of service	RFC 4987, TCP SYN Flooding Attacks and Common Mitigations	https://www.rfc-editor.org/rfc/rfc4987
Denial of service	RFC 2827 (BCP 38), Network Ingress Filtering	https://www.rfc-editor.org/rfc/rfc2827

Official references and further reading (3/3)

Topic	Resource	Full address (click to open)
Denial of service	MITRE ATT&CK T1498, Network Denial of Service	https://attack.mitre.org/techniques/T1498/
Denial of service	MITRE ATT&CK T1499, Endpoint Denial of Service	https://attack.mitre.org/techniques/T1499/
Denial of service	Canadian Centre for Cyber Security	https://www.cyber.gc.ca/en
Videos	Professor Messer SY0-701 course index	https://www.professormesser.com/security-plus/sy0-701/sy0-701-video/sy0-701-comptia-security-plus-course/
Legal references	Criminal Code of Canada, section 342.1	https://laws-lois.justice.gc.ca/eng/acts/c-46/section-342.1.html
Legal references	Criminal Code of Canada, section 430	https://laws-lois.justice.gc.ca/eng/acts/c-46/section-430.html
Legal references	Quebec Act respecting the protection of personal information in the private sector (Law 25 amendments)	https://www.legisquebec.gouv.qc.ca/en/document/cs/P-39.1
Legal references	PIPEDA	https://laws-lois.justice.gc.ca/eng/acts/P-8.6/
Legal references	GDPR, Regulation (EU) 2016/679	https://eur-lex.europa.eu/eli/reg/2016/679/oj
Legal references	US CFAA, 18 U.S.C. §1030	https://www.law.cornell.edu/uscode/text/18/1030
Legal references	EU Directive 2013/40/EU on attacks against information systems	https://eur-lex.europa.eu/eli/dir/2013/40/oj
Legal references	Spain, Ley Orgánica 10/1995 (Código Penal)	https://www.boe.es/buscar/act.php?id=BOE-A-1995-25444

Legal notice and responsible use

Acceptable use

- Educational purpose only: the material shows how to protect systems
- Practise only in your own isolated lab, or with written permission obtained before you start
- Never scan, probe or access a system that is not yours
- No real personal data or credentials in your deliverables
- **AI** (Artificial Intelligence) tools allowed: disclose the model and the exact prompts

Laws that apply

- Canada, Criminal Code: s. 342.1, s. 342.2, s. 430(1.1)
- Québec private-sector privacy law (Law 25) and **PIPEDA** (Personal Information Protection and Electronic Documents Act)
- Elsewhere: **GDPR** (General Data Protection Regulation), **US** (United States) **CFAA** (Computer Fraud and Abuse Act) (18 **U.S.C.** (United States Code) §1030), **EU** (European Union) Directive 2013/40/EU, Spain Ley Orgánica 10/1995
- No affiliation with any organization or product named; trademarks belong to their owners
- © 2026 Cyber.SoHo. Your own work belongs to you

Questions, then LAB_05 part 2



- After the 10:30 break: supervised lab time for LAB_05 part 2
- First the NM-LWS01 management rule, then its test, then the zoning rules
- Next: Class 13, Tuesday, September 29, 2026: Wi-Fi and cloud security practices
- Bring your rule set: you add the guest Wi-Fi zone to your design